

Problema 1 — Senhas Padrão e Fracas

O que foi encontrado: O Metasploitable usava `msfadmin:msfadmin` — a própria senha é igual ao nome do usuário. Foi a primeira combinação testada e funcionou imediatamente.

Por que é grave: Atacantes sempre começam por credenciais padrão conhecidas antes de qualquer wordlist. Sistemas que saem de fábrica com senhas padrão e não as trocam são comprometidos em segundos.

Correção

```
bash
```

```
# Trocar a senha de um usuário no Linux:
```

```
passwd msfadmin
```

```
# Forçar complexidade mínima via PAM:
```

```
sudo apt install libpam-pwquality -y
```

```
sudo nano /etc/pam.d/common-password
```

Adicione ou edite a linha:

```
password requisite pam_pwquality.so retry=3 minlen=12 dcredit=-1 ucredit=-1 ocredit=-1  
lcrypt=-1
```

Opção	Significado
minlen=12	Mínimo de 12 caracteres
2	
dcredit=-1	Pelo menos 1 número
-1	
ucredit=-1	Pelo menos 1 letra maiúscula
-1	
ocredit=-1	Pelo menos 1 símbolo especial
-1	
lcredit=-1	Pelo menos 1 letra minúscula
-1	

Exemplo de senha segura: `G#7kLm!pQ2@r`

Problema 2 — Sem Bloqueio de Conta (Account Lockout)

O que foi encontrado:

Account Lockout Threshold: None

O enum4linux revelou que o sistema **não bloqueia a conta** após tentativas de senha erradas. O Medusa testou dezenas de combinações sem nenhum obstáculo.

Por que é grave: Sem bloqueio, um atacante pode testar milhões de senhas sem limitação. Com um dicionário como `rockyou.txt` e múltiplas threads, o sistema inteiro seria comprometido em minutos.

Correção — via PAM (Linux)

```
bash
sudo nano /etc/pam.d/common-auth
```

Adicione no início do arquivo:

```
auth required pam_tally2.so onerr=fail audit silent deny=5 unlock_time=900
```

Opção	Significado
deny=5	Bloqueia após 5 tentativas falhas
unlock_time=900	Desbloqueia automaticamente após 15 minutos
audit	Registra as tentativas no log do sistema

Para verificar e desbloquear manualmente:

```
bash
# Ver contagem de tentativas falhas:
pam_tally2 --user msfadmin
```

```
# Desbloquear manualmente (ex: para o próprio admin):
pam_tally2 --user msfadmin --reset
```

Problema 3 — FTP sem Criptografia

O que foi encontrado: O FTP transmite usuário, senha e arquivos em **texto puro**. Qualquer pessoa na mesma rede consegue capturar as credenciais com um sniffer (ex: Wireshark).

Por que é grave: Mesmo que a senha seja forte, ela pode ser interceptada na transmissão antes de chegar ao servidor.

Correção — Substituir FTP por SFTP

O SFTP (SSH File Transfer Protocol) oferece a mesma funcionalidade do FTP, mas com **criptografia completa via SSH**:

```
bash
```

```
# Desativar FTP:
```

```
sudo systemctl stop vsftpd
```

```
sudo systemctl disable vsftpd
```

```
# O SFTP já vem habilitado com o SSH. Para conectar:
```

```
sftp msfadmin@192.168.56.101
```

```
# Para restringir um usuário ao SFTP (sem acesso SSH ao shell):
```

```
sudo nano /etc/ssh/sshd_config
```

Adicione ao final:

```
Match User msfadmin
```

```
    ForceCommand internal-sftp
```

```
    ChrootDirectory /home/msfadmin
```

```
    AllowTcpForwarding no
```

```
    X11Forwarding no
```

Problema 4 — Null Sessions habilitadas no SMB

O que foi encontrado:

```
[+] Server 192.168.56.101 allows sessions using username "", password ""
```

Qualquer pessoa pôde enumerar todos os usuários do sistema **sem fornecer nenhuma credencial**.

Por que é grave: A enumeração de usuários é o primeiro passo para ataques direcionados. Saber os nomes de usuário válidos elimina metade do trabalho de um atacante.

Correção — Desabilitar Null Sessions no Samba

```
bash
```

```
sudo nano /etc/samba/smb.conf
```

No bloco `[global]`, adicione:

```
ini
```

```
[global]
```

```
restrict anonymous = 2
null passwords = no
guest ok = no
```

Opção	Significado
restrict anonymous = 2	Bloqueia completamente sessões anônimas
null passwords = no	Não permite senhas em branco
guest ok = no	Desabilita acesso de convidado em todos os compartilhamentos

Aplicar as mudanças:

```
bash
sudo systemctl restart smb
```

Problema 5 — DVWA sem Proteção contra Força Bruta

O que foi encontrado: O formulário de login do DVWA não tem CAPTCHA, rate limiting nem bloqueio por IP. O Medusa encontrou 7 credenciais válidas em menos de 1 segundo.

Por que é grave: Qualquer aplicação web sem proteção contra múltiplas tentativas de login está vulnerável a ataques de dicionário automatizados.

1 — Fail2Ban para serviços web

```
bash
sudo apt install fail2ban -y
sudo nano /etc/fail2ban/jail.local
ini
[apache-auth]
enabled = true
port    = http,https
logpath = /var/log/apache2/error.log
maxretry = 5
bantime = 3600
findtime = 600
```

Opção	Significado
maxretry = 5	Bloqueia após 5 tentativas falhas

bantime = IP banido por 1 hora
3600

findtime = Janela de 10 minutos para contar as
600 tentativas

2 — Rate Limiting no Nginx

nginx

/etc/nginx/nginx.conf ou no bloco do servidor:

limit_req_zone \$binary_remote_addr zone=login_limit:10m rate=5r/m;

```
server {  
    location /dvwa/login.php {  
        limit_req zone=login_limit burst=10 nodelay;  
    }  
}
```

3 — Autenticação Multifator (MFA)

Mesmo que a senha seja descoberta, o segundo fator impede o acesso:

bash

Instalar Google Authenticator para SSH/sistemas:

sudo apt install libpam-google-authenticator -y

Configurar para o usuário:

google-authenticator

Siga o assistente: salve o QR Code no app autenticador

Habilitar no PAM:

sudo nano /etc/pam.d/sshd

Adicionar:

auth required pam_google_authenticator.so